

Tze Hui Liew (corresponding author)
Faculty of Information Science and Technology, Multimedia University
Melaka, Malaysia
thliew@mmu.edu.my

September 29, 2026

The Editor-in-Chief
Journal of Information Security and Applications

Submission of a Full Length Article: “It Is Not the Signature: A Pre-Authentication Key Parse Dominates JWT Validation in `jsonwebtoken` and Is Load-Bearing for Its Key-Confusion Defence”

Dear Editor,

We submit the above manuscript for consideration as a Full Length Article in the *Journal of Information Security and Applications* (JISA).

JSON Web Token validation is a common authentication step for microservice requests, and its cost is usually attributed to the signature. We show that in `jsonwebtoken`, a widely used Node.js implementation, the signature is under a tenth of the validation cost. The dominant component is a discarded attempt to parse the shared secret as an asymmetric key. The manuscript’s central contribution for this journal is the security analysis of that component:

- It runs *before authentication*, ahead of both the algorithm check and the signature check, so any well-formed token, forged or not, causes it, and pinning permitted algorithms does not prevent it.
- It entered the library with the release that fixed an RSA-to-HMAC key-confusion vulnerability (CVE-2022-23541), and the key-type checks that implement that fix depend on it. The obvious performance optimisation therefore fails the library’s own key-confusion tests.
- A narrow fix preserves the defence and makes validation 4.15 times faster, but an attacker-chosen algorithm header can still reach the parse; only a pre-parsed key removes it for every input. In our sample, 94% of call sites pin no algorithm and none pre-parses the key.

The magnitude of the cost is attributed causally to the bundled OpenSSL release: the same OpenSSL calls issued from C, against eight identically built releases, cost 394.4 μ s on 3.0.16 and 8.447 μ s on 3.5.8. It is confirmed by cgroup CPU accounting in a containerised service on a single-node Kubernetes testbed. A comparison of seven JWT libraries in four languages shows it follows a design choice rather than JWT validation as such.

We believe the work suits JISA because it is practice-driven research on a widely deployed security mechanism, linking measurement to engineering guidance: how a security hardening changes the cost of an authentication path, why performance changes to verification code must be reviewed as security changes, and what developers and library authors should do instead. It reports no new attack. The defect has been reported to the library maintainers (auth0/node-jsonwebtoken issue #1046), and the public report describes the constraint at the level of mechanism without an exploitation recipe. Every number in the paper is generated from committed data in an open replication package (doi:10.5281/zenodo.23011153).

This manuscript is original, has not been published previously, and is not under consideration for publication elsewhere. All authors have approved the manuscript and agree with its submission. The authors declare no competing interests. The use of generative AI in preparing the manuscript is declared in the manuscript.

Thank you for considering our submission.

Yours sincerely,

Tze Hui Liew, on behalf of all authors
Jannatul Ferdous Katha, Tasmia Tahmid Prova, Md Kishor Morol, Tze Hui Liew, Dip Nandi